API Integration Standards

API Versioning

To ensure compatibility and minimize disruptions during updates, all APIs must adhere to semantic versioning (MAJOR.MINOR.PATCH). For example, our current Carrier Management API is at version **2.1.0**. Any backward-incompatible changes will increment the MAJOR version, such as moving from 2.1.0 to **3.0.0**. MINOR versions introduce new functionality in a backward-compatible manner, like adding a new endpoint for real-time tracking. PATCH versions are used for bug fixes, e.g., **2.1.1**.

Internal reference code: CNRY-4aca4b3d.

Authentication and Authorization

Every API request must include a valid OAuth 2.0 token obtained from our Authorization Server at **auth.alderlinelogistics.eu**. The token must be included in the Authorization header as a Bearer token. For internal services, use the **internal-scope** scope, which grants access to endpoints such as `/v2/carriers/{id}` and `/v2/shipments`. External partners must use the **partner-scope** scope and will have limited access to endpoints like `/v2/shipments/status`. Token expiration is set to **3600 seconds (1 hour)**, after which a new token must be requested.

Rate Limiting

To prevent abuse and ensure fair usage, APIs are subject to rate limiting. The default rate limit is **100 requests per minute per API key**. For high-throughput services, such as our Warehouse Management System (WMS), a higher limit of **500 requests per minute** can be requested by submitting a form to the API Team. Rate limit headers are included in each response:

- `X-RateLimit-Limit`: The maximum number of requests allowed per window.
- `X-RateLimit-Remaining`: The number of requests remaining in the current window.
- `X-RateLimit-Reset`: The timestamp (in Unix epoch seconds) when the rate limit window resets.

Error Handling

APIs will return standard HTTP status codes to indicate the success or failure of a request. Common codes include:

- **200 OK**: The request has succeeded.
- **400 Bad Request**: The server cannot or will not process the request due to something that is perceived to be a client error.
- **401 Unauthorized**: Authentication is required or has failed.
- **404 Not Found**: The server can not find the requested resource.
- **429 Too Many Requests**: The user has exceeded rate limit. The `Retry-After` header will indicate how many seconds to wait before retrying.

All error responses will include a JSON body with a `code` and `message` field. For example:

```json
{
  "code": "INVALID_TOKEN",
  "message": "The access token is invalid or has expired."
}
```

These standards are effective from **2025-09-01** and will be reviewed annually.